giz

Information security standards for developing digital tools meant for GIZ's partners

The application is to be hosted in the partner's data center; the technical requirements for security must be coordinated with the partner's IT department in order to meet all the requirements of the ISO standards.

a virtual server must be provided for the project

A firewall must be installed upstream of the server.

Up-to-date anti-virus software must be used on the server and configured accordingly for automatic updates.

Separate environments for development, test and production must be provided.

Network communication between the components of the application should be encrypted.

Hard-coded keys (symmetric/asymmetric) should not be included in the application. If this is unavoidable, the handling of the key must be described. The information security risks related to the storage of the key must be evaluated.

The transmission of authentication information (especially passwords) must be encrypted. The storage and transmission of sensitive and/or personal data must comply with current encryption standards.

Separation of application and data is to be provided, i.e. an application server and a separate server for the database and file storage is provided, with communication through a firewall.

When configuring the web server, you must pay attention to the following:

- Disable Trace HTTP Request
- Run as a separate User & Group
- Disable signature
- Disable banner
- Restrict access to a specific network or IP
- Use only TLS 1.2 or higher
- Disable Directory Listing
- Remove unnecessary DSO modules
- Disable Null and Weak Ciphers
- periodically updates of the system -> stay current!
- periodically checks of the system log files

A system log is to be implemented in which at least logins and logouts of all users and actions such as updates, backups, uploads and downloads, changes to account data and authorizations, as well as all security-relevant actions and events are to be logged and documented. The inclusion of further log data is still to be discussed in detail with the project. The system log is to be documented in the operating manual.

The error messages generated by the application (especially exception handling/exceptions) must not provide any information that allows conclusions to be drawn about the architecture or software/software versions used.

Information about the framework used must not be included in the source code of the generated web pages.

The system must be hardened against SQL injection. In detail, this concerns the validation, filtering and cleansing of user input. The inputs may only have expected properties and characters and may not contain any unauthorized metacharacters that are passed to the SQL interpreter. When implementing API interfaces, it is essential to harden them against malicious code injection (SQL injection, etc.) via the URL.

The system must be protected against Cross Site Scripting (XXS) on the client side. The server(s) must be protected against reflected or persistent cross site scripting by securing the server source code. All data to be processed by the server must be validated before execution. Whitelists of permitted data can be used for this purpose. General conversion of certain script characters is also a popular method. It is to be prevented that executable metacharacters of the scripts are read by the server. Cookies should only be read by the server (HttpOnly) and not by JavaScript in the browser.

A password policy must be implemented, which should look like this:

- min. number of characters 10, for privileged accounts min. 16 characters
- Passwords for technical accounts must be at least 20 characters long, unless a
- regular password change (e.g. via managed service accounts) can be guaranteed
- The password must consist of 3 of the following 4 characteristics:
  - latin capital letters (A-Z)
  - lower case Latin letters (a-z)
  - basic digits (0-9)
  - non-alphanumeric characters (like !, $, #, -, &)
- the password must not contain all or part of your login name!
- after 10 wrong entries the account should be locked for 30 minutes
- max. password age 90 days
- password history, at least 10 different passwords in before a previously used password is accepted again, new passwords that differ only by consecutive numbers should not be accepted.

Passwords must not be stored in plain text. Passwords may only be stored as hash values. The hash algorithm must conform to the current recommendations of the BSI (technical guidelines).

Hard-coded passwords must not be included in the application. The transmission of authentication information (especially passwords) must be encrypted.

2-factor authentication is to be implemented; Google Authenticator is not to be used for this. 2FA is to be possible via multiple channels (app, SMS or e-mail).

Session cookies used for logins must be deleted after logging out from the client.

A role and authorization concept must be implemented that includes at least the roles of system admin (full authorization to the entire system), CMS admin (+account management), editor and author (editing content/articles). The application to be developed must be operable with minimal system rights. Only the following user groups may have access to the backend: Developers and administrators of the Contractor as well as employees for editorial maintenance of the Contractor.

Access to the backend at the operating system level may therefore only be granted to very limited user groups with the appropriate expertise.

There must be a documented authorization concept for each application (e.g. in the operating manual).

Changes to account data that are required for registration may only be made by the administrators and are to be blocked for the user.

In order to minimize operating errors (human errors), the ergonomics of the application should be designed safely according to the need for protection.

For the upload of files, appropriate file filters are to be provided so that no files with executable content (scripts, programs or SQL codes) can be uploaded and executed.

The regular backups of the complete system are to be coordinated with the project and the project-partner.

The deletion procedure must be proven upon request. Legal retention obligations remain unaffected.

Confidential information and data may only be transmitted by email in encrypted form. If it is not possible to encrypt the email, this content must be packed into a ZiP archive which is secured by a complex password (see password policy).

Only the SFTP protocol may be used for electronic file transfer, access must be secured with complex passwords (see password policy) and, if possible, 2FA should be used.

Remote maintenance of systems may only be carried out via secure communication channels such as HTTPS with an encryption standard of at least TLS 1.2 or higher. So-called VPNs can also be used for remote support and maintenance, these must be configured/secured by a firewall at the endpoints.